

HỌC VIỆN NGÂN HÀNG
KHOA CÔNG NGHỆ THÔNG TIN & KINH TẾ SỐ



CHƯƠNG I

TỔNG QUAN VỀ AN TOÀN BẢO MẬT

THÔNG TIN

Nội dung

1.1

Khái quát về ATBMTT

1.2

Các yêu cầu đảm bảo ATTT

1.3

Các thành phần của ATTT

1.4

Các bài toán ATTT

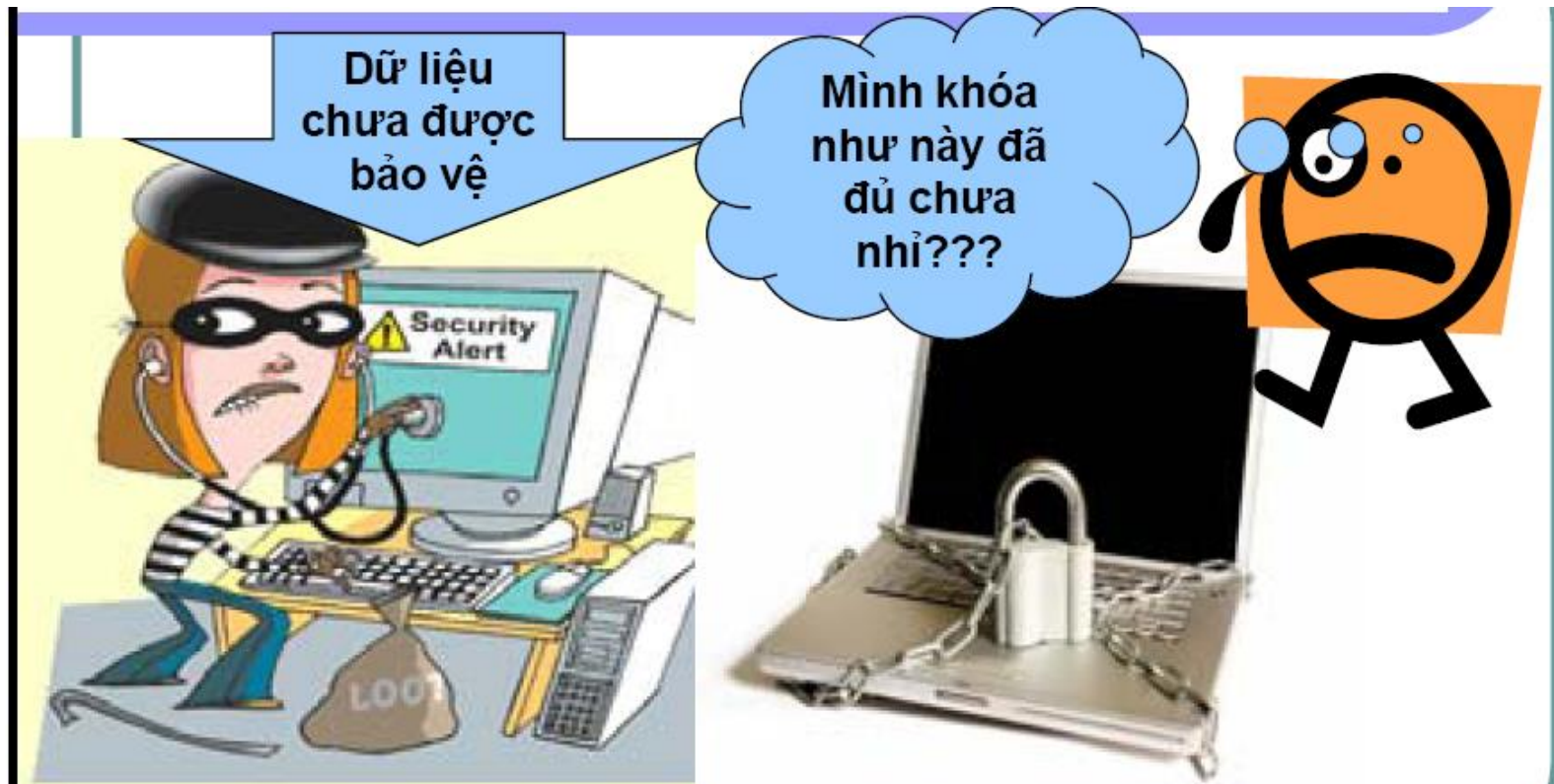
1.5

Chính sách, pháp luật về ATBMTT

1.1. Khái quát về ATBMTT

1.1.1 Khái niệm về ATTT

❖ An toàn dữ liệu là gì?



➡ Dữ liệu không bị hỏng hóc, không mất thông tin

1.1. Khái quát về ATBMTT

❖ An toàn thông tin là gì

- ❑ Là việc bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy thông tin một cách trái phép
- ❑ Là việc bảo vệ các thuộc tính bí mật (confidentiality), tính toàn vẹn (integrity) và tính sẵn dùng (availability) của các tài sản thông tin trong quá trình chúng được lưu trữ, xử lý, hoặc truyền tải

1.1. Khái quát về ATBMTT

1.1.2. Lĩnh vực chính của ATBMTT

- ❖ An toàn công nghệ thông tin (IT security)
- ❖ Đảm bảo thông tin

1.1. Khái quát về ATBMTT

1.1.3. Tại sao cần bảo đảm an toàn thông tin

- ❖ Tầm quan trọng của thông tin
- ❖ Sự xuất hiện của Internet và Thương mại điện tử
- ❖ Uy tín của các quốc gia, các tổ chức và các cá nhân

Phải đảm bảo an toàn cho những dữ liệu gì

❑ Đối với chính phủ :

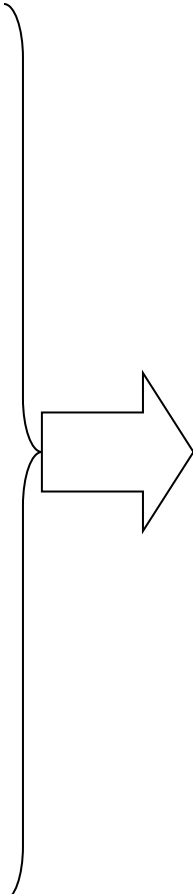
- Dữ liệu quân sự
- Dữ liệu ngoại giao
- Dữ liệu kinh tế
- Dữ liệu khoa học

❑ Đối với tổ chức :

- Dữ liệu nhạy cảm
- Dữ liệu mật của tổ chức

❑ Đối với cá nhân

- Dữ liệu cá nhân



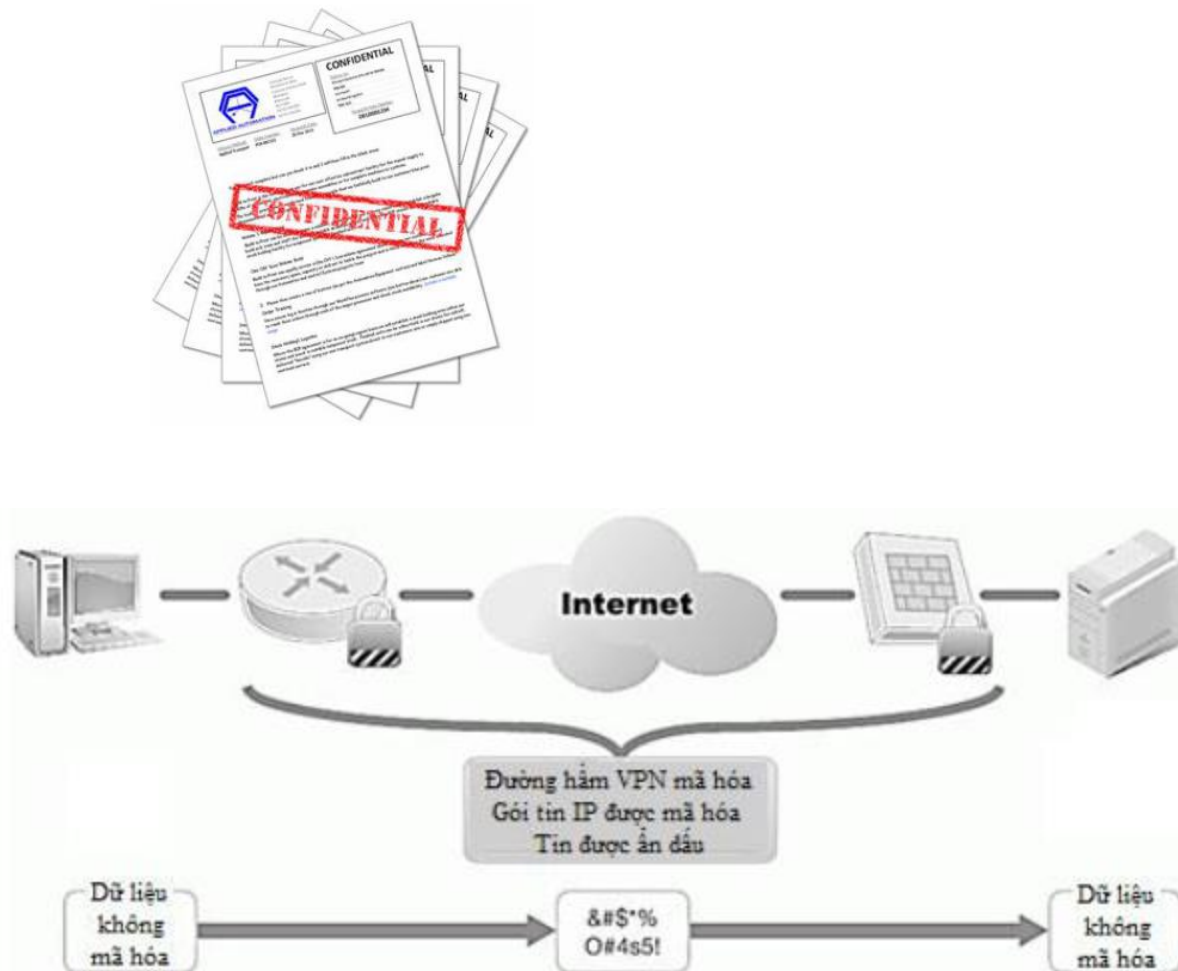
Tất cả
các dữ
liệu cần
phải được
bảo đảm
an toàn

1.2. Các yêu cầu đảm bảo ATTT

- ❖ **Bảo đảm bí mật (Bảo mật) - C**
- ❖ **Bảo đảm toàn vẹn (Bảo toàn) - I**
- ❖ **Bảo đảm xác thực (Chứng thực)**
- ❖ **Bảo đảm sẵn dùng - A**

1.2. Các yêu cầu đảm bảo ATTT

1.2.1 Bí mật



1.2. Các yêu cầu đảm bảo ATTT

1.2.2 Toàn vẹn

- ❖ Không bị thay đổi
- ❖ Chính xác
- ❖ Hợp lệ

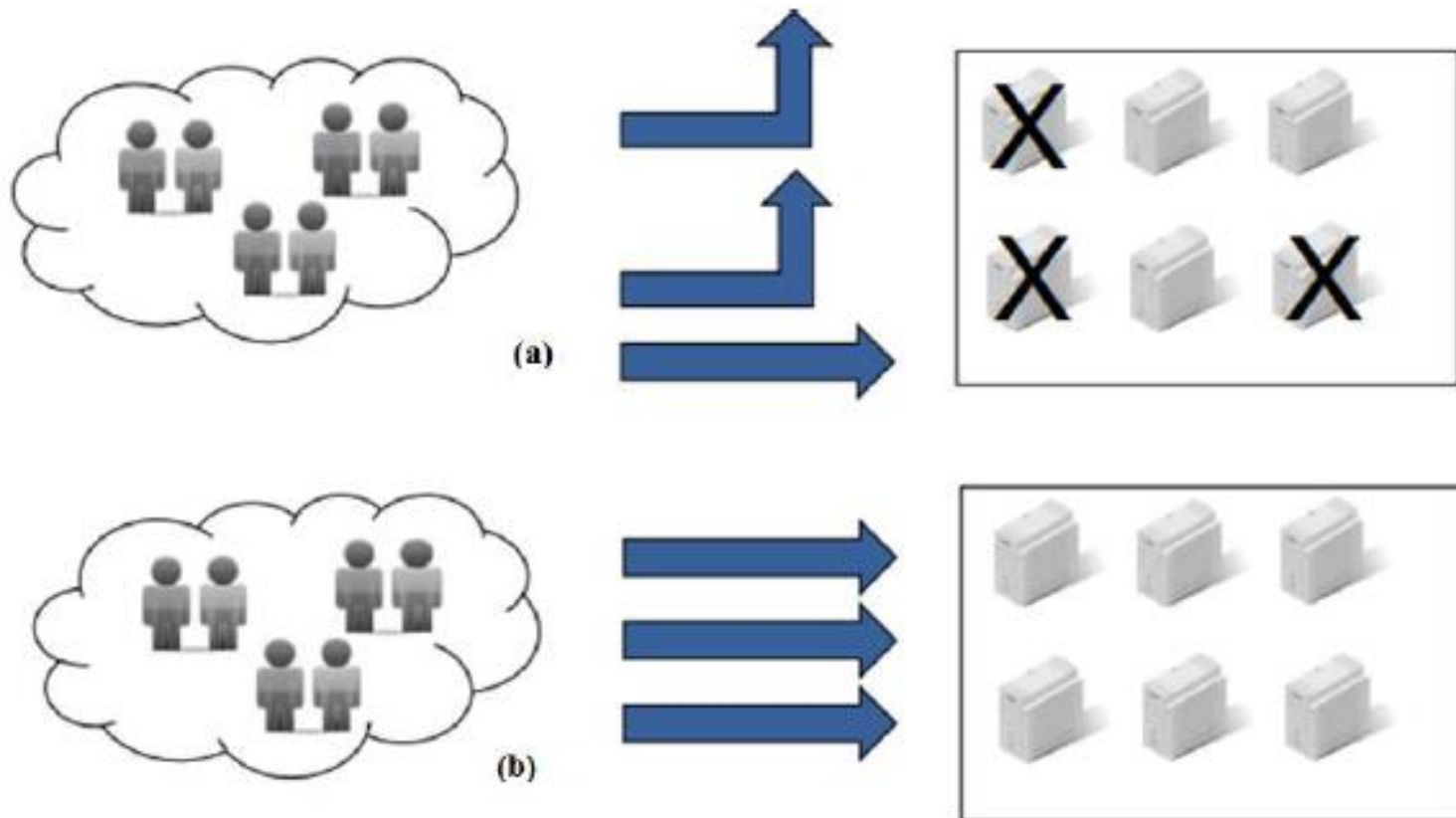
1.2. Các yêu cầu đảm bảo ATTT

1.2.3 Sẵn dùng

- ❖ Thời gian cung cấp dịch vụ (Uptime)
- ❖ Thời gian ngừng cung cấp dịch vụ (Downtime)
- ❖ Tỷ lệ phục vụ $A = \text{Uptime} / (\text{Uptime} + \text{Downtime})$
- ❖ Thời gian trung bình giữa các sự cố
- ❖ Thời gian trung bình ngừng để sửa chữa
- ❖ Thời gian khôi phục sau sự cố

1.2. Các yêu cầu đảm bảo ATTT

1.2.3 Sẵn dùng



1.3. Các thành phần của ATTT

❖ An toàn máy tính và dữ liệu

❖ An ninh mạng

❖ Quản lý an toàn thông tin

1.3. Các thành phần của ATTT

1.3.1 An toàn máy tính và dữ liệu

- ❖ Đảm bảo an toàn hệ điều hành, ứng dụng, dịch vụ
- ❖ Vấn đề điều khiển truy cập
- ❖ Vấn đề mã hóa và bảo mật dữ liệu
- ❖ Vấn đề phòng chống phần mềm độc hại
- ❖ Việc sao lưu tạo dự phòng dữ liệu

1.3. Các thành phần của ATTT

1.3.2 An ninh mạng

- ❖ Các tường lửa, proxy cho lọc gói tin và điều khiển truy cập
- ❖ Mạng riêng ảo và các kỹ thuật bảo mật thông tin truyền
- ❖ Các kỹ thuật và hệ thống phát hiện, ngăn chặn
- ❖ Vấn đề giám sát mạng

1.3. Các thành phần của ATTT

1.3.3 Quản lý an toàn thông tin

- ❖ Quản lý các rủi ro
- ❖ Chuẩn an toàn thông tin
- ❖ Chính sách an toàn thông tin
- ❖ Đào tạo, nâng cao ý thức an toàn thông tin của người dùng

1.4. Các bài toán ATTT

1.4.1 Công cụ đảm bảo ATBMTT

❖ Mật mã:

- ☐ Mã hóa
- ☐ Chữ ký số

❖ Giấu tin:

- ☐ Giấu tin
- ☐ Thủy ký

Ví dụ:

- ❑ **Ví dụ 1:** Giấu một thông tin sở hữu của người chủ vào trong tác phẩm (tài liệu số) của họ
- ❑ **Ví dụ 2:** Khi giấu một thông tin vào trong một tác phẩm (tài liệu số), với thông tin giấu nhằm kiểm xem tác phẩm có bị thay đổi nội dung hay không

1.4. Các bài toán ATTT

1.4.1 Công cụ đảm bảo ATBMTT

- ❖ **Nén thông tin:**

- ☐ Mã hóa độ dài cố định
- ☐ Mã hóa độ dài biến động
- ☐ Mã hóa Huffman

- ❖ **Tường lửa:**

- ❖ **Mạng riêng ảo**

1.4. Các bài toán ATTT

1.4.2 Các bài toán trong lý thuyết

❖ Bài toán bảo mật thông tin:

- ❑ Mã hóa độ dài cố định
- ❑ Mã hóa độ dài biến động
- ❑ Mã hóa Huffman

1.4. Các bài toán ATTT

1.4.2 Các bài toán trong lý thuyết

❖ Bài toán bảo toàn thông tin:

- ❑ Bảo toàn thông tin bằng các kỹ thuật : Nén thông tin, Mã hóa thông tin, Giấu tin
- ❑ Bảo toàn thông tin bằng các kỹ thuật : Hàm băm tạo đại diện bản tin
- ❑ Bảo toàn thông tin bằng các kỹ thuật : Chữ ký số
- ❑ Bảo toàn thông tin bằng các kỹ thuật : Thủy ký (WaterMarking)

1.4. Các bài toán ATTT

1.4.2 Các bài toán trong lý thuyết

❖ Bài toán xác thực :

- ❑ Các loại xác thực
- ❑ Các phương pháp xác thực
- ❑ Các công nghệ xác thực

❖ Bài toán cấp quyền , phân quyền :

- ❑ Cấp quyền cho người dùng hợp pháp, không cấp quyền cho người dùng bất hợp pháp
- ❑ Phân quyền cho đối tượng khác nhau

1.4. Các bài toán ATTT

1.4.2 Các bài toán trong lý thuyết

❖ Bài toán liên quan:

- ☐ Kiểm tra số nguyên tố lớn
- ☐ Tính phần tử nguyên thủy
- ☐ Tính toán số nguyên lớn
- ☐ Nhận dạng trong xác thực
- ☐ Định danh trong xác thực
- ☐ Chứng minh không tiết lộ thông tin
- ☐ Chống chối cãi

❖ Bài toán công cụ tính toán: Tính toán “Mềm”, Tính toán song song, Tính toán “hiệu năng cao”, Tính toán “lười”, ...

1.4. Các bài toán ATTT

1.4.3 Các bài toán trong Ứng dụng

❖ Bài toán xây dựng cơ sở hạ tầng An toàn thông tin:

- ❑ Tường lửa
- ❑ Mạng riêng ảo
- ❑ Hệ thống cấp chứng chỉ số (CA)
- ❑ Cơ sở hạ tầng mật mã Khóa công khai (PKI)
- ❑ Cơ sở hạ tầng ATTT phục vụ cho hệ thống tính toán và di động

1.4. Các bài toán ATTT

1.4.3 Các bài toán trong Ứng dụng

❖ Bài toán bảo vệ bản quyền bản tin số :

- ☐ Ký số
- ☐ Thủy ký
- ☐ Giải pháp Lưu vết và Thu hồi thiết bị thu bắt hợp pháp

❖ Bài toán kinh tế xã hội:

- ☐ Kiểm tra từ xa
- ☐ Bỏ phiếu từ xa
- ☐ Đấu thầu từ xa
- ☐ Giao dịch chứng khoán từ xa

1.5. Chính sách, pháp luật về ATTT

1.5.1 Chính sách, pháp luật ATBMTT

❖ Giới thiệu về pháp luật và chính sách ATTT :

❑ Chính sách (Policy):

❑ Luật:

❑ Đạo đức

1.5. Chính sách, pháp luật về ATTT

1.5.1 Chính sách, pháp luật ATBMTT

❖ Các yêu cầu đảm bảo chính sách có thể được áp dụng hiệu quả :

- ☐ Có khả năng phổ biến rộng rãi
- ☐ Có thể xem, hiểu được
- ☐ Rõ ràng, dễ hiểu
- ☐ Cần biện pháp để nhân viên cam kết thực hiện
- ☐ Cần được thực hiện đồng đều, bình đẳng, nhất quán

1.5. Chính sách, pháp luật về ATTT

1.5.2 Luật quốc tế về ATTT

❖ Luật tội phạm máy tính:

- ❑ Computer Fraud and Abuse Act of 1986 (CFA Act)
- ❑ Computer Security Act, 1987
- ❑ National Information Infrastructure Protection Act of 1996
- ❑ USA PATRIOT Act, 2001
- ❑ USA PATRIOT Improvement and Reauthorization Act

1.5. Chính sách, pháp luật về ATTT

1.5.2 Luật quốc tế về ATTT

❖ Luật riêng tư bảo vệ quyền riêng tư người dùng:

- ❑ Federal Privacy Act, 1974
- ❑ Electronic Communications Privacy Act , 1986
- ❑ Health Insurance Portability and Accountability Act, 1996 (HIPAA)
- ❑ Financial Services Modernization Act or Gramm-Leach-Bliley Act, 1999

1.5. Chính sách, pháp luật về ATTT

1.5.2 Luật quốc tế về ATTT

❖ Luật xuất khẩu và chống gián điệp:

- ❑ Economic Espionage Act, 1996

- ❑ Security and Freedom through Encryption Act, 1999

1.5. Chính sách, pháp luật về ATTT

1.5.2 Luật quốc tế về ATTT

❖ Luật xuất khẩu và chống gián điệp:

- ❑ Hội đồng Châu Âu về chống tội phạm mạng (Council of Europe Convention on Cybercrime)
- ❑ Hiệp ước về chống tội phạm mạng được Hội đồng châu Âu phê chuẩn vào năm 2001
- ❑ Hiệp ước bảo vệ quyền sở hữu trí tuệ (Agreement on Trade-Related Aspects of Intellectual Property Rights (TRIPS))
- ❑ Digital Millennium Copyright Act (DMCA)

1.5. Chính sách, pháp luật về ATTT

1.5.3 Luật Việt Nam về ATTT

- ❖ Luật ATTT mạng
- ❖ Các văn bản liên quan

- ❑ Luật công nghệ thông tin số 67/2006/QH11
- ❑ Nghị định số 90/2008/NĐ-CP
- ❑ Quyết định số 59/2008/QĐ-BTTTT
- ❑ Quyết định 63/QĐ-TTg của Thủ tướng CP

1.5. Chính sách, pháp luật về ATTT

1.5.3 Luật Việt Nam về ATTT

- ❖ Luật ATTT mạng
- ❖ Các văn bản liên quan

- ❑ Chỉ thị số 897/CT-TTg của Thủ tướng CP
- ❑ Thông tư số 23/2011/TT-BTTTT
- ❑ Nghị định số 77/2012/NĐ-CP của Chính Phủ
- ❑ Nghị định 72/2013/NĐ-CP

1.5. Chính sách, pháp luật về ATTT

1.5.4 Vấn đề đạo đức ATTT

- ❖ **Sự cần thiết:**
- ❖ **Một số bộ quy tắc ứng xử trong CNTT và ATTT**
- ❑ Trong lĩnh vực CNTT và ATTT chưa có bộ quy tắc ứng xử bắt buộc
- ❑ ACM (Association for Computing Machinery) và ISSA (Information Systems Security Association) hợp tác để đề ra các quy tắc ứng xử trong an toàn thông tin
- ❑ Hiệp hội an toàn thông tin Việt Nam đã công bố Bộ Quy tắc ứng xử an toàn thông tin vào đầu năm 2015

1.5. Chính sách, pháp luật về ATTT

1.5.4 Vấn đề đạo đức ATTT

❑ Bộ quy tắc ứng xử của Viện đạo đức máy tính (Mỹ)

1. Không được sử dụng máy tính để gây hại cho người khác;
2. Không được can thiệp vào công việc của người khác trên máy tính;
3. Không trộm cắp các file trên máy tính của người khác;
4. Không được sử dụng máy tính để trộm cắp;
5. Không được sử dụng máy tính để tạo bằng chứng giả;
6. Không sao chép hoặc sử dụng phần mềm không có bản quyền;
7. Không sử dụng các tài nguyên máy tính của người khác khi không được phép hoặc không có bồi thường thỏa đáng;
8. Không chiếm đoạt tài sản trí tuệ của người khác;
9. Nên suy nghĩ về các hậu quả xã hội của chương trình mình đang xây dựng hoặc hệ thống đang thiết kế;
10. Nên sử dụng máy tính một cách có trách nhiệm, đảm bảo sự quan tâm và tôn trọng đến đồng bào của mình.

1.5. Chính sách, pháp luật về ATTT

1.5.4 Vấn đề đạo đức ATTT

❑ Một số vấn đề khác

- Sự khác biệt về vấn đề đạo đức giữa các nền văn hóa
- Vi phạm bản quyền phần mềm
- Lạm dụng các tài nguyên của cơ quan tổ chức



Thank You !